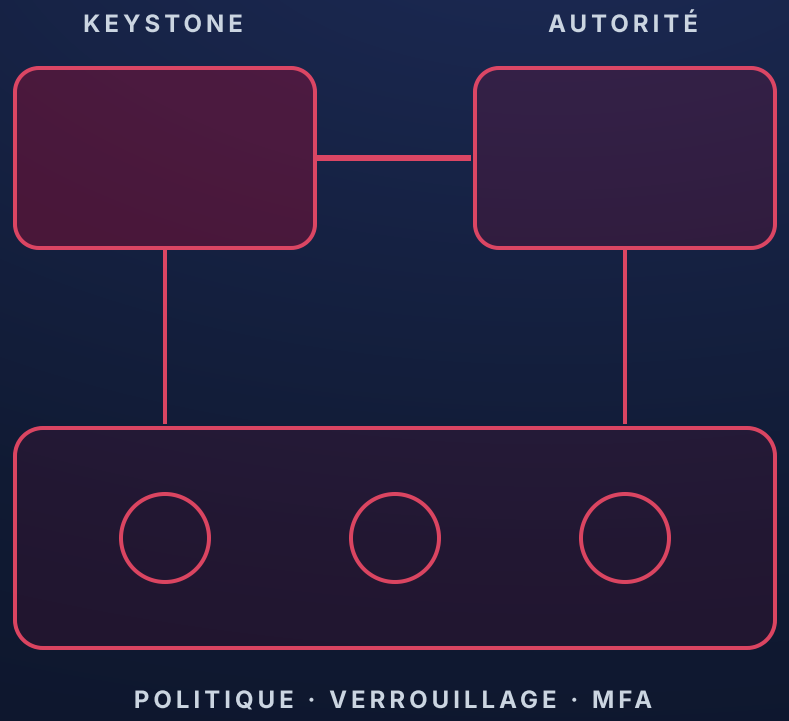
COMPRENDRE OPENSTACK · MODULE 11

Authentification externe et mots de passe

Fédération d'identité avec une autorité d'authentification externe, et politique de mots de passe selon le référentiel de l'ANSSI, sur Canonical OpenStack (Sunbeam)



OpenID Connect · SAML 2 · Règles de correspondance · Guide ANSSI 2021 · Verrouillage · Comptes de service

Version déployée : Canonical OpenStack 2026.1 LTS, donc OpenStack 2026.1 · ANSSI, Recommandations relatives à l'authentification multifacteur et aux mots de passe, v2.0, 8 octobre 2021

INTRODUCTION

Objectif et déroulé

Objectif : confier l'authentification des personnes à une autorité externe, raccordée à Keystone par fédération, et appliquer une politique de mots de passe conforme aux recommandations de l'ANSSI — là où elle doit s'appliquer, sans mettre en panne les comptes de service.

À l'issue de ce module, vous saurez :

- Expliquer pourquoi et comment déléguer l'authentification à une **autorité externe**.
- Décrire les objets de la **fédération** dans Keystone et le déroulé d'une connexion.
- Écrire et tester des **règles de correspondance**.
- Raccorder un fournisseur d'identité à un cloud **Sunbeam**, pas à pas.
- Traduire le guide de l'**ANSSI** en règles : longueur, complexité, expiration, verrouillage.
- Appliquer ces règles dans Keystone sans casser les **comptes de service**.

1 · Pourquoi une autorité externe
Local, annuaire ou fédération ; vocabulaire ; OIDC et SAML ; choisir son fournisseur.

2 · La fédération dans Keystone
Objets, flux, règles de correspondance, sécurité, limites.

3 · La fédération sur Sunbeam
Prérequis, pas à pas, vérification, pannes.

4 · Le référentiel ANSSI
Longueur, complexité, expiration, verrouillage, stockage, multifacteur.

5 · Appliquer dans Keystone
Options de conformité, stratégie sur Sunbeam.

6 · Les comptes de service
Risques, exemptions, ordre d'activation.

01

Pourquoi une autorité d'authentification externe

Un cloud ne devrait pas être un annuaire de plus. Les personnes ont déjà une identité dans l'entreprise, avec sa politique, son multifacteur et sa procédure de départ : Keystone doit s'y fier, pas la recopier.

- Identité locale ou externe
- Le vocabulaire de la fédération
- Choisir son fournisseur
- Trois façons de raccorder
- OpenID Connect ou SAML 2

1 · AUTORITÉ EXTERNE

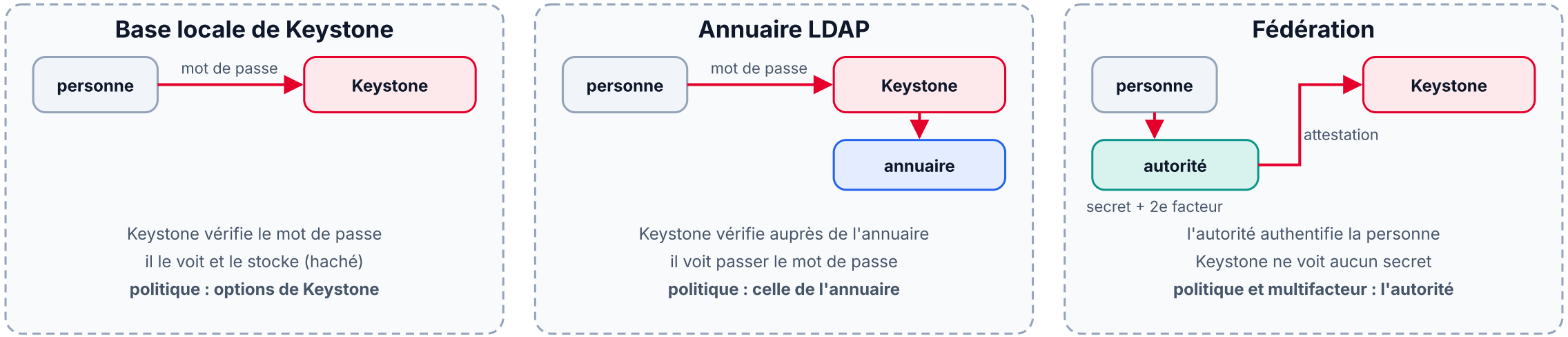
Identité locale ou identité externe

Sujet	Comptes locaux dans Keystone	Autorité externe, par fédération
Où vit le mot de passe	**dans la base de Keystone, haché**	chez l'autorité ; Keystone ne le voit jamais
Politique de mot de passe	**options de Keystone, globales**	celle de l'autorité, déjà appliquée à toute l'entreprise
Multifacteur	**TOTP de Keystone, compte par compte**	celui de l'autorité : application, clé physique, carte
Départ d'un salarié	**à désactiver dans Keystone, en plus du reste**	désactivé une fois, chez l'autorité : plus de nouvelle connexion
Droits	**affectations aux comptes ou aux groupes**	groupes de l'autorité, traduits en groupes Keystone par des règles
Traçabilité	**journaux de Keystone**	journaux de l'autorité et de Keystone, avec le même identifiant
Dépendance	**aucune**	l'autorité doit être joignable pour se connecter

Principe : une seule source de vérité par personne. Chaque compte local supplémentaire est un mot de passe de plus à protéger, à faire expirer, à révoquer au départ.

Ce qui reste local : les comptes des services OpenStack, un ou deux comptes d'administration de secours, et les comptes techniques des automates. Ils sont l'objet de la dernière partie.

Trois façons de raccorder des identités



- **Annuaire LDAP :** Keystone lit l'annuaire et vérifie lui-même le mot de passe. Il le voit passer — et la politique de verrouillage ou d'expiration est celle de l'annuaire.
- **Fédération :** Keystone ne voit ni mot de passe ni second facteur. Il reçoit une attestation signée par l'autorité, et en tire utilisateur et groupes.
- **Les trois coexistent,** un domaine par source : comptes techniques en local, salariés par l'annuaire ou la fédération, partenaires par une autre fédération.
- **Sur Sunbeam :** `sunbeam ldap add-domain` pour un annuaire, `sunbeam identity provider add` pour une fédération.

1 · AUTORITÉ EXTERNE Principe vu au module 8

Le vocabulaire de la fédération

Terme	Sens
Fournisseur d'identité (IdP)	**l'autorité : authentifie la personne et atteste son identité**
Fournisseur de service (SP)	**l'application qui fait confiance à l'attestation — ici Keystone**
Attestation	**jeton d'identité signé (OIDC) ou assertion signée (SAML)**
Attribut, revendication	**une information de l'attestation : identifiant, courriel, groupes**
Client, client secret	**l'enregistrement du SP chez l'IdP (OIDC) et son secret**
URL de redirection	**adresse du SP où l'IdP renvoie le navigateur après authentification**
Émetteur, identifiant distant	**nom unique de l'IdP ; Keystone le compare à ce qu'il a enregistré**
Règles de correspondance	**traduisent les attributs reçus en utilisateur, groupes, projets**

Ce qui se passe, en une phrase : Keystone renvoie le navigateur vers l'autorité ; l'autorité authentifie ; elle renvoie une attestation signée ; Keystone la vérifie, applique ses règles et délivre un jeton OpenStack.

- **La confiance est configurée, pas négociée :** Keystone connaît d'avance l'émetteur, ses clés de signature et l'identifiant de client.
- **L'autorité ne connaît pas OpenStack :** elle ne sait rien des projets ni des rôles. Elle fournit des attributs ; les règles de Keystone en tirent des droits.
- **Le jeton OpenStack reste un jeton Keystone :** les services ne voient jamais l'attestation. Pour eux, un utilisateur fédéré est un utilisateur comme un autre.

> Le module 8 présente la fédération dans les grandes lignes ; ce module en détaille le fonctionnement, la sécurité et la mise en œuvre.

1 · AUTORITÉ EXTERNE

OpenID Connect ou SAML 2

Critère	OpenID Connect (OIDC)	SAML 2
Fondation	**OAuth 2.0, jetons JSON signés (JWT)**	assertions XML signées
Configuration	**adresse de découverte de l'émetteur, identifiant et secret de client**	échange de fichiers de métadonnées, certificats
Fournisseurs courants	**Keycloak, Entra ID, Okta, Google, Canonical Identity Platform**	ADFS, Shibboleth, Keycloak, Entra ID
Ligne de commande	**possible : mot de passe délégué, autorisation par appareil, jeton d'accès**	difficile : protocole pensé pour le navigateur
Dans Keystone	**protocole `openid`, module Apache `mod_auth_openidc`**	protocole `saml2`, module Apache `mod_auth_mellon` ou Shibboleth
Sur Sunbeam	**chemin documenté :** `sunbeam identity provider add … openid`	le charm prévoit une paire de clés SAML ; procédure à vérifier

Choix par défaut : OIDC. Plus simple à configurer, utilisable en ligne de commande, et c'est le chemin que Canonical documente pour Sunbeam.

SAML 2 reste pertinent quand l'autorité de l'entreprise ne parle que lui — un ADFS ancien par exemple — ou pour une fédération entre établissements qui l'impose.

1 · AUTORITÉ EXTERNE

Choisir son autorité d'authentification

Autorité	Hébergement	Politique de mot de passe	Multifacteur	Sur Sunbeam
Keycloak	**chez vous**	règles par domaine : longueur, historique, expiration, détection de force brute	TOTP, WebAuthn, clés physiques	OIDC générique : vérifier les types acceptés par la commande
Canonical Identity Platform	**chez vous, déployée par Juju**	celle de son propre stockage d'identités, ou de l'autorité amont	selon la configuration	**type `canonical`, documenté**
Entra ID	**nuage Microsoft**	politique du locataire Microsoft	accès conditionnel, application	**type `entra`, documenté**
Okta	**nuage Okta**	politique de l'organisation Okta	application, clés physiques	**type `okta`, documenté**
Google	**nuage Google**	politique du compte Google Workspace	validation en deux étapes	**type `google`, documenté**
ADFS, Shibboleth	**chez vous**	celle de l'annuaire derrière	selon le produit	SAML : à vérifier

Critère n° 1 : là où sont déjà les personnes

Le meilleur fournisseur est celui que l'entreprise exploite déjà, avec ses procédures d'arrivée et de départ.

Critère n° 2 : la maîtrise

Un cloud privé souverain s'accommode mal d'une authentification hébergée hors de l'Union : l'autorité devient un point de dépendance.

Critère n° 3 : la disponibilité

Autorité indisponible = plus aucune connexion humaine : d'où le compte de secours (partie 6).

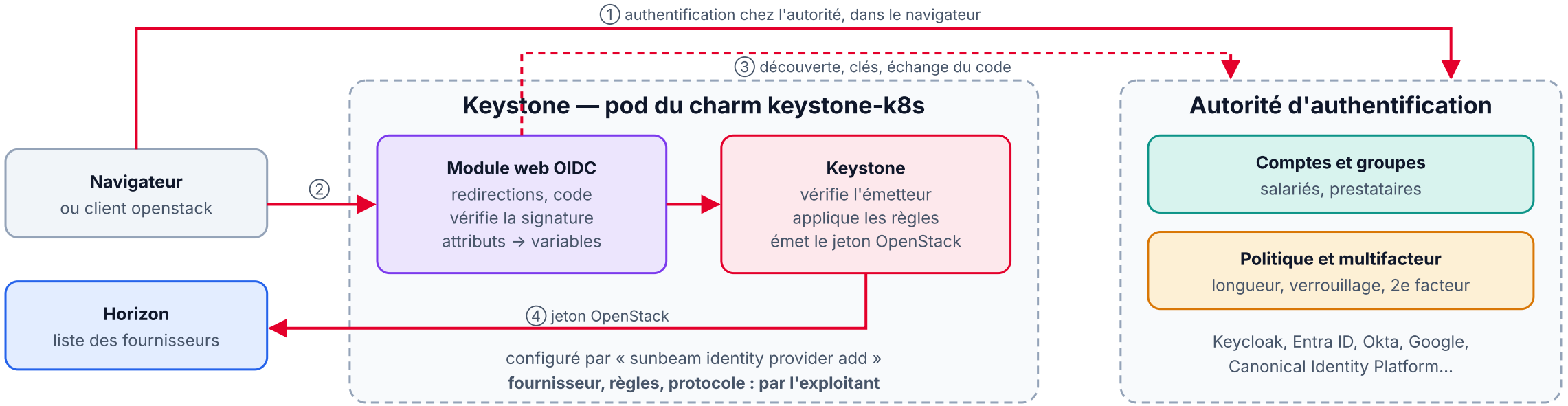
02

La fédération dans Keystone

Trois objets dans Keystone, un module dans le serveur web, et des règles qui traduisent des attributs en droits. Comprendre ces pièces permet de diagnostiquer presque toutes les pannes de connexion fédérée.

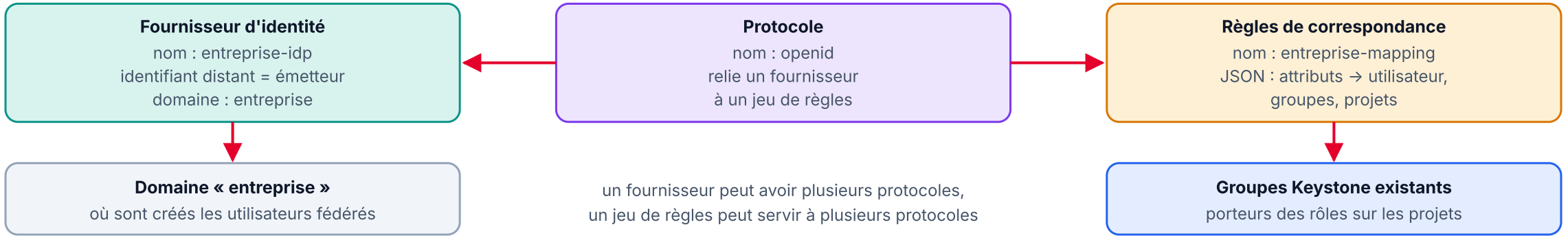
- Architecture
- Connexion par le navigateur
- Les règles de correspondance
- Tester une règle
- Les trois objets
- Connexion en ligne de commande
- Utilisateurs et groupes fédérés
- Sécurité et limites

Architecture



- **Le module web fait le protocole** — redirections, échange du code, vérification de la signature — et transmet les attributs à Keystone sous forme de variables d'environnement.
- **Keystone fait l'autorisation :** il vérifie l'émetteur, applique les règles, crée ou retrouve l'utilisateur et émet un jeton.
- **Le préfixe des attributs** dépend de la configuration du module : `OIDC-email`, `HTTP_OIDC_EMAIL`… Les règles de correspondance doivent utiliser exactement ces noms.
- **Horizon** propose le fournisseur dans sa liste de connexion et reçoit le jeton en retour.

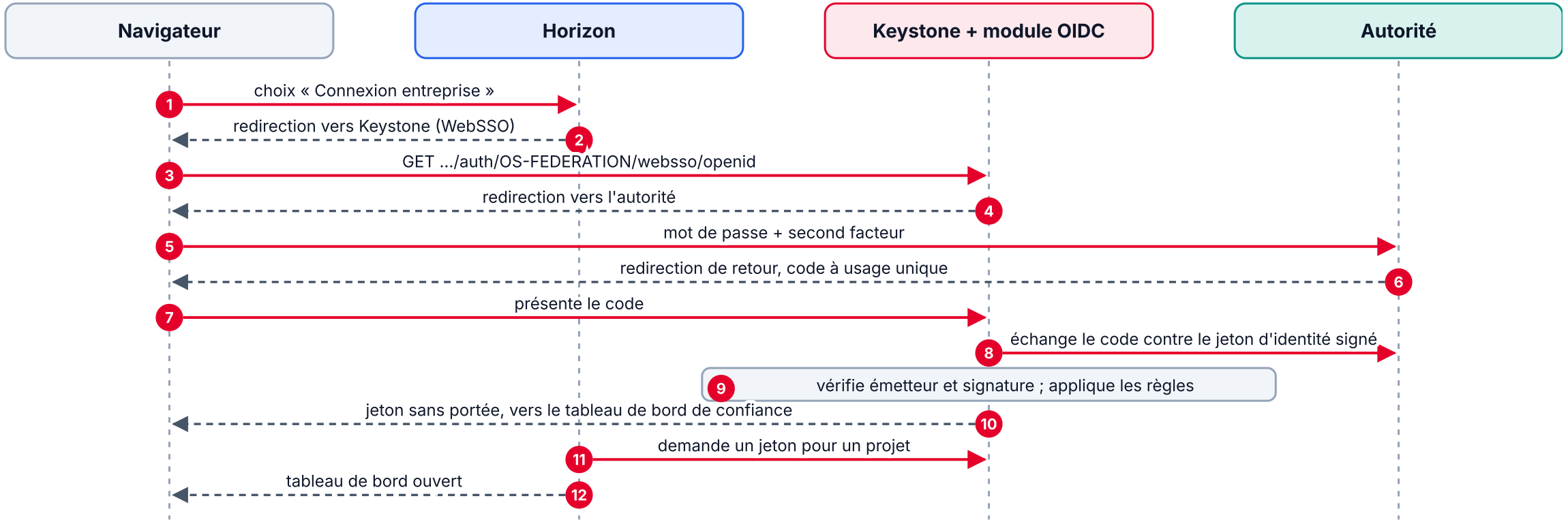
Les trois objets de Keystone




```
# Prérequis : identifiants d'administrateur
source admin-openrc
openstack identity provider create entreprise-idp \
  --remote-id https://sso.exemple.fr/realms/entreprise \
  --domain entreprise
openstack mapping create entreprise-mapping --rules rules.json
openstack federation protocol create openid \
  --identity-provider entreprise-idp --mapping entreprise-mapping
```

- **Identifiant distant :** doit être égal, caractère pour caractère, à l'émetteur présenté par l'attestation — barre oblique finale comprise.
- **Domaine du fournisseur :** les utilisateurs fédérés y sont créés ; un domaine par fournisseur.
- **Le nom du protocole** fait partie des adresses de connexion : `…/identity_providers/entreprise-idp/protocols/openid/auth`.

Connexion par le navigateur (WebSSO)



- **Le mot de passe et le second facteur** ne sont saisis que chez l'autorité (étape 4) : ni Horizon ni Keystone ne les voient.
- **Le premier jeton est sans portée :** il dit qui est l'utilisateur. Horizon en demande ensuite un pour un projet.
- **Tableau de bord de confiance :** Keystone ne renvoie le jeton qu'à une adresse d'Horizon déclarée d'avance — protection contre le vol de jeton par redirection.
- **Aucun rôle, aucun projet ?** La connexion réussit chez l'autorité, puis échoue dans Horizon : la règle n'a donné aucun groupe utile.

Connexion en ligne de commande

Méthode (`auth_type`)	Principe et usage
`v3oidcpassword`	le client envoie identifiant et mot de passe à l'autorité ; contourne le multifacteur ; souvent désactivé par les autorités
`v3oidcdeviceauthz`	le client affiche un code ; la personne le valide dans un navigateur, avec son multifacteur
`v3oidcclientcredentials`	un programme s'authentifie comme client de l'autorité ; pour les automates
`v3oidcaccesstoken`	un jeton d'accès déjà obtenu est présenté à Keystone
`v3oidcauthcode`	code d'autorisation obtenu par ailleurs

> **Recommandé pour les personnes :** l'autorisation par appareil, qui conserve le multifacteur. À défaut, se connecter à Horizon et y créer un identifiant d'application.

```
# ~/.config/openstack/clouds.yaml
clouds:
  entreprise:
    auth_type: v3oidcdeviceauthz
    auth:
      auth_url: https://keystone.exemple.fr/v3
      identity_provider: entreprise-idp
      protocol: openid
      client_id: openstack-cli
      discovery_endpoint: >-
        https://sso.exemple.fr/realms/ent/.well-known/openid-configuration
      project_name: prod-web
      project_domain_name: nord

# Le client affiche une adresse et un code à valider
openstack --os-cloud entreprise token issue
```

- **Le client OIDC de la ligne de commande** doit être déclaré chez l'autorité, avec le flux correspondant autorisé.
- **Méthode disponible selon la version** de keystoneauth installée : vérifier avant de la proposer aux équipes.

Les règles de correspondance : anatomie

```
[
  {
    "local": [
      { "user":  { "name": "{0}", "email": "{1}" } },
      { "group": { "name": "exploitation-prod",
                   "domain": { "name": "entreprise" } } }
    ],
    "remote": [
      { "type": "OIDC-preferred_username" },
      { "type": "OIDC-email" },
      { "type": "OIDC-groups",
        "any_one_of": [ "openstack-exploitation" ] }
    ]
  },
  {
    "local": [
      { "user":  { "name": "{0}", "email": "{1}" } },
      { "group": { "name": "developpeurs",
                   "domain": { "name": "entreprise" } } }
    ],
    "remote": [
      { "type": "OIDC-preferred_username" },
      { "type": "OIDC-email" },
      { "type": "OIDC-groups",
        "any_one_of": [ "openstack-dev" ] }
    ]
  }
]
```

Partie	Rôle
`remote`	ce que l'attestation doit contenir ; toutes les conditions doivent être vraies
`local`	ce que Keystone en tire : utilisateur, groupes, éventuellement projets
`{0}`, `{1}`	valeur du 1er, du 2e attribut de `remote`, dans l'ordre
Groupe local	doit exister dans Keystone et porter les rôles

- **Les droits ne sont pas dans la règle :** elle ne fait que placer la personne dans un groupe Keystone ; les rôles sont affectés au groupe, comme pour tout autre utilisateur.
- **Les règles se cumulent :** une personne présente dans les deux groupes de l'autorité reçoit les deux groupes Keystone.
- **Aucune règle ne correspond :** refus de la connexion (401). C'est le comportement par défaut voulu — n'entre que qui est prévu.

> Noms d'attributs d'exemple ; leur forme exacte dépend du module web et de l'autorité.

Les conditions sur les attributs

Condition	Effet	Usage
`any_one_of`	**vraie si l'une des valeurs est présente**	appartenance à un groupe de l'autorité
`not_any_of`	**fausse si l'une des valeurs est présente**	exclure les comptes externes, les comptes suspendus
`whitelist`	**ne garde que les valeurs listées**	transmettre seulement certains groupes
`blacklist`	**retire les valeurs listées**	écarter des groupes sensibles
`regex: true`	**les valeurs sont des expressions régulières**	domaine de courriel, préfixe de groupe

Ordre et cumul : chaque règle qui réussit ajoute ses groupes. Une règle d'exclusion doit donc être portée par chaque règle d'accès — par une condition `not_any_of` — et non par une règle séparée.

```
# Seuls les salariés du domaine de courriel de l'entreprise,
# et jamais les comptes marqués « suspendu »
"remote": [
  { "type": "OIDC-preferred_username" },
  { "type": "OIDC-email",
    "any_one_of": [ ".*@exemple\\.fr$" ], "regex": true },
  { "type": "OIDC-groups",
    "not_any_of": [ "comptes-suspendus" ] },
  { "type": "OIDC-groups",
    "any_one_of": [ "openstack-dev" ] }
]

# Transmettre tels quels tous les groupes « os-* »
"local": [
  { "user": { "name": "{0}" } },
  { "groups": "{1}", "domain": { "name": "entreprise" } }
],
"remote": [
  { "type": "OIDC-preferred_username" },
  { "type": "OIDC-groups",
    "any_one_of": [ "^os-.*" ], "regex": true }
]
```

Transmettre des groupes en masse est pratique mais délègue à l'autorité le pouvoir d'ouvrir des droits : quiconque peut créer un groupe « os-… » chez elle en devient maître.

Utilisateurs et groupes fédérés

Type d'utilisateur	Comportement
éphémère (par défaut)	**créé à la première connexion dans le domaine du fournisseur ; attributs venus de l'autorité**
local	**doit exister déjà dans Keystone ; la fédération ne sert qu'à l'authentifier ; ses groupes et rôles locaux s'appliquent**

- **Appartenance aux groupes :** recalculée à chaque connexion à partir de l'attestation. Quitter le groupe chez l'autorité retire le droit à la connexion suivante.
- **Utilisateur « fantôme » :** Keystone garde une trace de chaque utilisateur fédéré — identifiant stable, dernière connexion — ce qui permet audit et affectations directes.
- **Appartenance persistante :** pour qu'un identifiant d'application ou une délégation d'un utilisateur fédéré reste valable entre deux connexions, Keystone peut conserver l'appartenance pendant une durée réglée sur le fournisseur (`authorization_ttl`) — à vérifier sur votre version.

Départ d'un salarié

Moment	Effet
Compte désactivé chez l'autorité	plus de nouvelle connexion
Jetons Keystone déjà émis	valides jusqu'à expiration, quelques heures
Identifiants d'application créés par lui	à supprimer : ils ne passent pas par l'autorité
Ressources qu'il a créées	restent dans les projets : elles appartiennent au projet

La fédération ne coupe pas tout : la procédure de départ doit inclure la suppression des identifiants d'application ; pour un départ sensible, tenir compte de la durée de vie des jetons déjà émis.

```
# Utilisateurs fédérés et leurs identifiants
openstack user list --domain entreprise
openstack application credential list --user <id>
```

Créer les projets automatiquement ?

```
"local": [
  { "user": { "name": "{0}" } },
  { "projects": [
      { "name": "bac-a-sable-{0}",
        "roles": [ { "name": "member" } ] }
  ] }
],
"remote": [
  { "type": "OIDC-preferred_username" },
  { "type": "OIDC-groups",
    "any_one_of": [ "openstack-bac-a-sable" ] }
]
```

- **Effet :** à la première connexion, Keystone crée le projet s'il n'existe pas et y affecte le rôle à l'utilisateur.
- **Ces affectations persistent** dans Keystone, même si la règle change ensuite : il faut les retirer à la main.
- **Les projets ainsi créés** reçoivent les quotas par défaut : ceux-ci deviennent la seule protection.

Pour	Contre
Libre-service immédiat	**prolifération de projets jamais supprimés**
Pas de demande à l'équipe plateforme	**droits persistants hors de l'autorité**
Utile en formation, en recherche	**déconseillé en production**

> **Recommandation :** en production, les projets se créent par la plateforme ou le gestionnaire du domaine ; la fédération ne fait que placer les personnes dans des groupes existants.

> Si l'on garde l'auto-création : quotas par défaut très bas, étiquette d'échéance, et revue mensuelle des projets créés ainsi.

Tester une règle avant de la publier

```
# 1 · Un fichier d'attributs, tels que l'autorité les envoie
cat > alice.txt <<'EOF'
OIDC-preferred_username: alice
OIDC-email: alice@exemple.fr
OIDC-groups: openstack-dev;comptes-standard
EOF

# 2 · Le moteur de correspondance, hors ligne
keystone-manage mapping_engine \
  --rules rules.json --input alice.txt

# 3 · Sur Sunbeam : dans le conteneur de Keystone
sudo k8s kubectl -n openstack cp rules.json \
  keystone-0:/tmp/rules.json -c keystone
sudo k8s kubectl -n openstack cp alice.txt \
  keystone-0:/tmp/alice.txt -c keystone
sudo k8s kubectl -n openstack exec keystone-0 -c keystone -- \
  keystone-manage mapping_engine \
  --rules /tmp/rules.json --input /tmp/alice.txt

# 4 · Publier la règle
openstack mapping set entreprise-mapping --rules rules.json
```

Jeu d'essai minimal

Cas	Résultat attendu
Membre de `openstack-dev`	groupe `developpeurs`
Membre des deux groupes	les deux groupes
Membre d'aucun groupe prévu	aucune correspondance : refus
Compte suspendu	refus
Courriel d'un autre domaine	refus

- **Une règle se publie comme du code :** fichier versionné, revue par un second, jeu d'essai rejoué à chaque modification.
- **Récupérer les attributs réels :** journaux de Keystone en mode débogage lors d'une connexion d'essai, puis désactiver le débogage.

> Le moteur hors ligne ne vérifie pas que les groupes et domaines existent ; l'essai réel reste nécessaire.

Sécuriser la fédération

Point	Risque	Mesure
Transport	**vol de code ou de jeton en clair**	TLS partout : Keystone, Horizon, autorité ; URL de redirection en https
Identifiant distant	**un autre émetteur se fait passer pour l'autorité**	identifiant distant exact, un fournisseur par émetteur
Secret du client	**fuite : n'importe qui se fait passer pour Keystone auprès de l'autorité**	secret long, stocké en secret Juju, renouvelé ; jamais dans un dépôt
Règles trop larges	**tout compte de l'autorité entre dans le cloud**	conditions explicites ; aucune règle sans condition de groupe
Groupes transmis en masse	**un administrateur de l'autorité ouvre des droits OpenStack**	liste fermée de groupes, revue conjointe
Horloges	**attestations refusées, ou acceptées trop longtemps**	NTP sur tous les nœuds et chez l'autorité
Disponibilité de l'autorité	**plus aucune connexion humaine**	compte local de secours (partie 6)
Multifacteur	**contourné par le flux « mot de passe » en ligne de commande**	désactiver ce flux chez l'autorité ; autorisation par appareil

La fédération déplace la confiance : l'autorité devient un composant critique du cloud. Ses administrateurs, ses journaux et sa disponibilité relèvent du même niveau d'exigence que ceux de Keystone.

Limites à connaître

Limite	Conséquence et contournement
Groupes recalculés à chaque connexion	**identifiants d'application et délégations d'un utilisateur fédéré peuvent perdre leurs droits ; durée d'appartenance persistante, ou compte technique local**
Pas de révocation à la source	**désactiver chez l'autorité n'invalide pas les jetons déjà émis ; durée de vie courte des jetons**
Ligne de commande	**selon les flux autorisés par l'autorité ; sinon, passer par Horizon et un identifiant d'application**
Un domaine par fournisseur	**un même salarié présent dans deux fournisseurs = deux utilisateurs**
Politique de Keystone	**les options de conformité de Keystone — verrouillage, expiration — ne s'appliquent pas aux utilisateurs fédérés : c'est l'autorité qui décide**

Ce que la fédération apporte

- une seule politique de mot de passe, celle de l'entreprise ;
- le multifacteur sans rien développer ;
- des départs traités une fois ;
- aucun mot de passe humain dans Keystone.

Ce qu'elle n'apporte pas

- les droits OpenStack : ils restent à concevoir dans Keystone ;
- l'authentification des services et des automates ;
- une révocation instantanée des sessions ouvertes.

> C'est la dernière ligne du tableau qui fait le lien avec la suite : une fois les personnes fédérées, la politique de mots de passe de Keystone ne concerne plus que les comptes locaux.

03

La fédération sur Sunbeam

Sunbeam configure le module web, l'enregistrement du fournisseur et Horizon. Il reste à l'exploitant ce qui relève de ses choix : le domaine, les groupes, les rôles et les règles de correspondance.

- Ce que Sunbeam fait, ce qui reste à faire
- Pas à pas : le fournisseur
- Vérifier
- Prérequis
- Pas à pas : Keystone
- Exploiter et dépanner

Ce que Sunbeam fait, ce qui reste à faire

Étape	Qui la fait	Commande ou action
Déclarer Keystone comme client chez l'autorité	**l'exploitant, chez l'autorité**	URL de redirection donnée par `sunbeam identity provider get-oidc-redirect-url`
Configurer le module OIDC de Keystone	**Sunbeam**	`sunbeam identity provider add`
Proposer le fournisseur dans Horizon	**Sunbeam**	automatique : le nom choisi sert d'étiquette
Créer le domaine du fournisseur	**l'exploitant**	`openstack domain create`
Enregistrer le fournisseur dans Keystone	**l'exploitant**	`openstack identity provider create`, même nom que dans Sunbeam
Groupes, projets, rôles	**l'exploitant**	module 10 (projets), module 12 (rôles, moindre privilège)
Règles de correspondance et protocole	**l'exploitant**	`openstack mapping create`, `openstack federation protocol create`
Retirer le fournisseur	**Sunbeam, puis l'exploitant**	`sunbeam identity provider remove` ne supprime pas les objets créés avec `openstack`

Types documentés par Canonical : `canonical` (Canonical Identity Platform), `google`, `okta`, `entra`, tous en OpenID Connect. Pour un autre fournisseur — Keycloak par exemple —, consulter `sunbeam identity provider add --help` sur votre version.

Prérequis

Prérequis	Pourquoi, comment
TLS sur les points d'accès publics	la plupart des autorités refusent une URL de redirection en http ; Sunbeam le fait avec Vault
Nom de domaine complet	certaines autorités — Google — refusent une adresse IP
Résolution et accès réseau	Keystone doit joindre l'autorité (découverte, clés, échange du code) ; le navigateur aussi
Horloges synchronisées	validité des attestations
Client déclaré chez l'autorité	identifiant, secret, URL de redirection, revendications utiles — dont les groupes
Compte local de secours	voir partie 6

```
# Étape 0 — TLS des points d'accès publics par Vault
# (Vault activé, initialisé, descellé, autorisé :
#  voir la documentation « Enable Vault »)
sunbeam enable tls vault \
  --ca "$(base64 -w0 ca.pem)" \
  --ca-chain "$(base64 -w0 chaine.pem)"

# Points d'accès : doivent être en https
source admin-openrc
openstack endpoint list --interface public \
  -c "Service Name" -c URL

# L'URL de redirection à déclarer chez l'autorité
sunbeam identity provider get-oidc-redirect-url \
https://cloud.exemple.fr/openstack-keystone/v3/\
OS-FEDERATION/protocols/openid/redirect_uri
```

> L'option `--ca-chain` s'omet avec un certificat autosigné. La remise des certificats signés à Vault fait l'objet d'une procédure à part, selon l'autorité de certification.

Pas à pas (1) : déclarer le fournisseur

```
# Exemple : Entra ID
cat > entra.yaml <<'EOF'
client-id: 1b2c…
client-secret: "••••••••"
microsoft-tenant: 7f3e…
label: Connexion entreprise
EOF
chmod 600 entra.yaml

sunbeam identity provider add entra openid \
  entreprise-idp --config entra.yaml

# Vérifier, et lire l'émetteur pour la suite
sunbeam identity provider list
sunbeam identity provider list --format=yaml

# Supprimer le fichier : le secret est désormais
# conservé par le déploiement
shred -u entra.yaml
```

Type	Champs du fichier
`google`	`client-id`, `client-secret`, `label`
`okta`	idem + `okta-org`
`entra`	idem + `microsoft-tenant`
`canonical`	offres Juju du modèle `iam` : `oauth_offer`, `cert_offer`

- **Le nom choisi** — `entreprise-idp` — sera repris tel quel dans Keystone ; il apparaît dans Horizon sous l'étiquette.
- **Le secret du client** ne doit pas traîner dans l'historique ni dans un dépôt : fichier en mode 600, supprimé après usage.

> La documentation écrit les clés tantôt avec tiret, tantôt avec soulignement : vérifier la forme attendue par votre version.

Pas à pas (2) : les objets de Keystone

```
# Prérequis : identifiants d'administrateur
source admin-openrc
ISSUER=$(sunbeam identity provider list --format=yaml \
  | yq -r '."entreprise-idp".issuer_url')
# (syntaxe de la documentation Canonical)

# 1 · Domaine dédié au fournisseur
openstack domain create entreprise \
  --description "Utilisateurs fédérés — Entra ID"

# 2 · Fournisseur : MÊME nom que dans Sunbeam
openstack identity provider create entreprise-idp \
  --remote-id "$ISSUER" --domain entreprise

# 3 · Groupes porteurs des rôles
openstack group create developpeurs --domain entreprise
openstack role add member \
  --group developpeurs --group-domain entreprise \
  --project rec-web --project-domain nord
```

```
# 4 · Règles de correspondance, testées hors ligne
openstack mapping create entreprise-mapping \
  --rules rules.json

# 5 · Protocole : relie fournisseur et règles
openstack federation protocol create openid \
  --identity-provider entreprise-idp \
  --mapping entreprise-mapping

# Relire l'ensemble
openstack identity provider show entreprise-idp
openstack federation protocol list \
  --identity-provider entreprise-idp
openstack mapping show entreprise-mapping
```

Groupes et projets peuvent être dans des domaines différents : le groupe vit dans le domaine du fournisseur ; il reçoit des rôles sur les projets du domaine « nord ».

Le nom du protocole, `openid`, est celui que le module configuré par Sunbeam attend.

Pas à pas (3) : vérifier

Essai	Résultat attendu
Horizon : le fournisseur apparaît dans la liste	étiquette choisie
Connexion d'un membre de `openstack-dev`	redirection, multifacteur chez l'autorité, retour dans Horizon, projet `rec-web` visible
Connexion d'un salarié hors groupe	refus à l'arrivée dans Keystone
L'utilisateur fédéré existe	dans le domaine `entreprise`
Ses droits effectifs	`member` sur `rec-web`, rien d'autre
Retrait du groupe chez l'autorité	plus de projet à la connexion suivante
Compte local de secours	connexion possible par le domaine local

```
# Après une première connexion d'alice
openstack user list --domain entreprise
openstack role assignment list --effective --names \
  --user <id-alice>

# Journaux de Keystone pendant un essai
sudo k8s kubectl -n openstack logs keystone-0 \
  -c keystone --since 5m | grep -i -e federation -e mapping

# État des unités et de la relation avec l'autorité
juju status -m openstack keystone --relations
```

Mettre le niveau de journalisation en débogage

(`juju config -m openstack keystone log-level=DEBUG`) permet de lire les attributs reçus — à remettre à `WARNING` aussitôt : ces journaux contiennent des données personnelles.

Pannes typiques

Symptôme	Cause probable	Vérification
L'autorité refuse : « redirect URI mismatch »	**URL déclarée chez l'autorité différente de celle de Keystone**	`get-oidc-redirect-url`, comparer caractère par caractère
Retour dans Keystone, erreur 401	**aucune règle ne correspond, ou groupe inexistant**	attributs reçus dans les journaux ; moteur de correspondance hors ligne
« Could not find Identity Provider »	**nom différent entre Sunbeam et Keystone**	`sunbeam identity provider list` et `openstack identity provider list`
Erreur sur l'émetteur	**identifiant distant inexact**	barre oblique finale, http au lieu de https
Connexion réussie, aucun projet	**groupe sans rôle, ou rôle sur un autre projet**	`role assignment list --effective`
Échecs intermittents	**horloge décalée ; une unité de Keystone mal configurée**	NTP ; journaux de chaque unité
Fonctionnait, ne fonctionne plus	**secret du client expiré chez l'autorité**	date d'expiration du secret côté autorité

> **Le secret d'un client chez Entra ID ou Okta expire** selon la durée choisie à sa création : noter la date et planifier son renouvellement, sinon toutes les connexions s'arrêtent le même jour.

04

Le référentiel ANSSI : mots de passe et multifacteur

Le guide de l'ANSSI de 2021 rompt avec des habitudes anciennes : la longueur prime sur la complexité, l'expiration systématique n'est plus recommandée pour tous, le multifacteur devient la norme dès que l'enjeu monte.

- Le guide et ses principes
- Complexité et listes interdites
- Verrouillage et temporisation
- Renouvellement et récupération
- Comptes à privilèges
- Longueur et entropie
- Expiration
- Stockage
- Multifacteur
- De la règle à la valeur

Le guide et ses principes

Référence : ANSSI, *Recommandations relatives à l'authentification multifacteur et aux mots de passe*, version 2.0, 8 octobre 2021. Recommandations numérotées R1 à R38.

N°	Principe
R1	privilégier l'authentification multifacteur
R2	privilégier des mécanismes robustes, conformes au RGS
R3	choisir les moyens d'authentification après une analyse de risque
R10	limiter le nombre de tentatives dans le temps
R13	protéger les données d'authentification stockées
R31	fournir un gestionnaire de mots de passe et former à son usage

Trois idées à retenir

Adapter à l'enjeu

Il n'y a pas une politique, mais des politiques : un compte d'administration du cloud n'a pas le même niveau d'exigence qu'un compte de lecture d'un projet d'essai.

La longueur d'abord

Un mot de passe long résiste mieux qu'un mot de passe court et « complexe », que les utilisateurs construisent selon des schémas prévisibles.

Le mot de passe seul ne suffit pas

Pour les accès sensibles — l'administration en tête — le guide recommande un second facteur, de préférence de possession.

Longueur et entropie (R21)

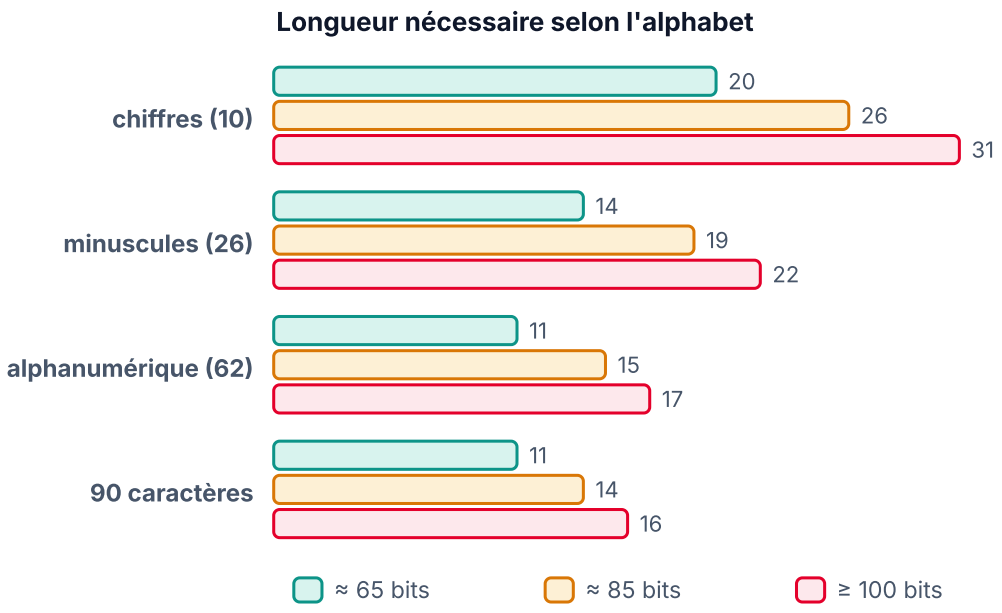


Tableau du guide — alphabet de 90 caractères

Sensibilité	Longueur minimale	Équivalent
Faible à moyenne	**9 à 11**	≈ 65 bits
Moyenne à forte	**12 à 14**	≈ 85 bits
Forte à très forte	**15 et plus**	≥ 100 bits

- **Forte à très forte sensibilité :** le guide recommande en plus le multifacteur.
- **Mots de passe non mémorisés** — ceux d'un gestionnaire, d'un compte technique — : au moins 20 caractères.
- **Code court acceptable** seulement avec des mesures fortes : blocage définitif après trois échecs, comme une carte à puce.

Pour un cloud : les comptes d'administration relèvent de la sensibilité forte ; un compte de travail ordinaire, au minimum de la moyenne à forte.

Calcul : longueur × $\log_2$(taille de l'alphabet). Valable seulement pour un tirage aléatoire uniforme — ce que n'est presque jamais un mot de passe choisi par une personne.

Complexité, longueur maximale, listes interdites

N°	Recommandation
R22	ne pas imposer de longueur maximale, pour permettre les phrases de passe ; seulement une borne technique de quelques centaines de caractères
R23	imposer des règles de complexité à la création et au renouvellement, en autorisant le plus large jeu de caractères
R27	interdire la réutilisation des derniers mots de passe ; vérifier à la création les listes de mots de passe courants ou compromis, les suites prévisibles, les informations personnelles

Ce que dit le guide des règles de complexité : elles se contournent facilement hors ligne (« a » devient « @ ») ; elles sont surtout utiles contre les attaques en ligne, avec une limitation des tentatives.

Traduction pratique

Règle	Valeur proposée
Longueur minimale	12 caractères, 15 pour les comptes à privilèges
Longueur maximale	aucune, ou ≥ 128
Jeu de caractères	tous, espace et accents compris
Classes imposées	au plus deux ; la longueur fait le reste
Historique	5 derniers interdits
Liste de refus	mots de passe compromis connus, nom de l'entreprise, identifiant

Valeurs proposées pour ce module, à valider par votre analyse de risque. La vérification contre des listes de mots de passe compromis relève de l'autorité d'authentification : Keystone ne sait pas la faire.

Expiration (R24, R25, R26)

R24 — Comptes ordinaires

Si la robustesse est imposée et que le système le permet : **pas d'expiration par défaut**. Le guide note qu'une expiration courte, de 3 à 6 mois, peut être contre-productive : les utilisateurs incrémentent un chiffre.

R25 — Comptes à privilèges

Imposer une expiration, par exemple **entre 1 et 3 ans**. Le guide préfère, pour ces comptes, une authentification à deux facteurs.

R26 — Compromission suspectée

Renouveler sans délai — dans la journée — tous les mots de passe concernés ; à défaut, désactiver les comptes et prévoir une procédure de réactivation.

Habitude ancienne	Problème	Pratique conforme au guide
Expiration à 90 jours pour tous	**mots de passe prévisibles : « Printemps2026! »**	pas d'expiration pour les comptes ordinaires robustes
Jamais d'expiration pour l'administration	**un mot de passe ancien a eu le temps de fuiter**	1 à 3 ans, plus multifacteur
Attendre l'expiration après une fuite	**fenêtre d'exploitation ouverte**	renouvellement immédiat, procédure prête

Dans Keystone, l'expiration est une option globale : elle ne distingue pas comptes ordinaires et privilégiés. On la module compte par compte avec une option d'exemption — partie 5.

Verrouillage et temporisation (R10)



- **R10 :** limiter le nombre de tentatives sur une période — blocage temporaire de quelques secondes ou minutes après plusieurs échecs, linéaire ou exponentiel.
- **Un blocage définitif** n'est envisagé par le guide que pour des codes courts protégés autrement — une carte à puce, par exemple.
- **Le revers du verrouillage :** quiconque connaît un identifiant peut le bloquer en tapant de faux mots de passe. Sur un compte de service, c'est une panne du cloud.
- **R14 :** en multifacteur, un échec ne doit pas révéler quel facteur a échoué.

Stockage des mots de passe (R13, R28, R29)

N°	Recommandation
R13	protéger en confidentialité et en intégrité les données d'authentification stockées ; en restreindre l'accès
—	ne jamais stocker un mot de passe en clair : interdit absolu
R28	sel aléatoire propre à chaque compte, d'au moins 128 bits
R29	état de l'art : fonction de dérivation coûteuse en mémoire — scrypt, Argon2 — réglée au plus fort que l'usage permet
R29-	à défaut : PBKDF2, avec le plus grand nombre d'itérations possible

Dans Keystone — `[identity] password_hash_algorithm`

Valeur	Au regard du guide
`bcrypt`	valeur par défaut ; robuste, mais ni l'une ni l'autre des familles citées
`bcrypt_sha256`	variante sans troncature à 72 octets
`scrypt`	conforme à R29
`pbkdf2_sha512`	conforme à R29-

- **Changement transparent :** à la connexion suivante réussie, Keystone recalcule l'empreinte avec le nouvel algorithme. Les comptes qui ne se connectent jamais gardent l'ancienne.
- **R13 sur Sunbeam :** la base de Keystone vit dans la grappe MySQL du déploiement ; accès au nœud de contrôle, sauvegardes et secrets Juju sont à protéger au même niveau.

> Sur Sunbeam, l'algorithme n'est pas exposé par le charm : bcrypt reste en place. Les mots de passe des personnes, une fois fédérées, ne sont plus stockés dans Keystone.

Mots de passe initiaux, récupération, défauts

N°	Recommandation
R30	prévoir une méthode de récupération adaptée — mot de passe temporaire, lien à usage unique, assistance — ; ne jamais renvoyer le mot de passe d'origine en clair
R38	changer les mots de passe par défaut des comptes natifs dès l'installation
R18, R19	organiser la révocation et en fixer les délais selon l'analyse de risque
R33, R35	un mot de passe différent par service ; ni papier, ni fichier, ni courriel

> **Mot de passe temporaire** remis par l'administration : il doit être changé dès la première connexion. Keystone le permet (`change_password_upon_first_use`).

Sur un cloud Sunbeam

Compte natif	Action
`admin` **créé à l'installation**	mot de passe tiré au sort par le déploiement : le garder dans un coffre, restreindre `sunbeam openrc`
Utilisateur de démonstration	créé par `sunbeam configure` : à supprimer ou désactiver en production
Comptes des services	secrets générés par les charms : ne pas y toucher
Images d'instances	pas de mot de passe par défaut ; accès par clé, injectée au démarrage

- **Récupération pour les personnes fédérées :** celle de l'autorité — le cloud n'a rien à prévoir.
- **Pour les comptes locaux :** réinitialisation par l'administration, avec changement imposé à la première connexion.

Multifacteur (R1, R8, R14)

Catégorie	Exemples	Remarque
Connaissance	**mot de passe, code**	le facteur le plus exposé
Possession	**clé physique, carte à puce, application de code à usage unique**	préférée par le guide
Inhérence	**empreinte, visage**	sur l'appareil de la personne

- **R1 :** deux facteurs de catégories différentes — deux mots de passe ne font pas un multifacteur.
- **R8 :** ne pas utiliser le SMS pour transmettre un facteur.
- **R14 :** un échec ne doit pas dire lequel des facteurs a échoué.

Où le mettre en œuvre

Population	Moyen
Personnes fédérées	multifacteur de l'autorité, imposé pour l'application OpenStack
Comptes locaux d'administration	TOTP de Keystone : règle « mot de passe + totp »
Compte de secours	TOTP, secret sous scellé avec le mot de passe, séparément
Comptes de service, automates	sans objet : secrets longs, identifiants d'application

Le multifacteur de l'autorité ne protège que ses propres flux : si le flux « mot de passe » en ligne de commande reste ouvert, il le contourne. Le fermer chez l'autorité.

Les comptes à privilèges

Qu'est-ce qu'un compte à privilèges sur un cloud OpenStack ?

Compte	Pourquoi
Détenteurs de `admin`	administrent tout le cloud
Gestionnaires de domaine	créent comptes et affectations
Comptes des services OpenStack	détiennent `admin` et `service`
Accès aux nœuds, à Juju, à Vault	contournent toute politique de Keystone
Administrateurs de l'autorité	peuvent ouvrir des droits par les groupes

La dernière ligne est souvent oubliée : avec la fédération, l'administrateur de l'autorité est un administrateur du cloud par procuration.

Exigences renforcées

- **Multifacteur obligatoire** pour toute personne détenant un de ces droits.
- **Mot de passe d'au moins 15 caractères,** expiration entre 1 et 3 ans (R25).
- **Comptes dédiés :** le compte d'administration n'est pas le compte de messagerie.
- **Nombre minimal** et revue mensuelle.
- **Poste d'administration maîtrisé :** le guide de l'ANSSI sur l'administration sécurisée des systèmes d'information le développe.

Pour les comptes de service, l'enjeu est le même mais les moyens diffèrent : pas de multifacteur possible, donc des secrets très longs, jamais saisis par une personne, et un accès restreint à leur stockage.

De la règle à la valeur : une politique par population

Règle	Personnes, compte ordinaire	Personnes, à privilèges	Compte local de secours	Compte de service
Où il vit	**autorité externe**	autorité externe	Keystone, domaine local	Keystone, domaine des services
Longueur	**≥ 12**	≥ 15	≥ 20, tiré au sort	≥ 20, tiré au sort
Complexité	**largeur du jeu de caractères, liste de refus**	idem	sans objet : aléatoire	sans objet : aléatoire
Expiration	**aucune (R24)**	1 à 3 ans (R25)	1 an, et après chaque usage	rotation planifiée, hors expiration automatique
Historique	**5**	5	5	sans objet
Verrouillage	**temporisation après 5 à 10 échecs**	idem	temporisation, alerte	exempté — surveillance des échecs
Multifacteur	**recommandé**	obligatoire	obligatoire (TOTP)	impossible : secret protégé à la place
Inactivité	**désactivation après 90 jours**	idem	exempté — revue périodique	exempté
Premier usage	**selon l'autorité**	selon l'autorité	changement imposé	exempté

Valeurs proposées, à adapter : elles découlent du guide (R10, R21, R24, R25, R27) et d'une analyse de risque type ; elles ne remplacent pas la vôtre.

Lecture : deux colonnes se règlent chez l'autorité, deux dans Keystone. Les exemptions de la dernière colonne évitent de mettre le cloud en panne — partie 6.

Où s'applique chaque règle

Autorité d'authentification
les personnes

- longueur, liste de refus
- historique, expiration
- temporisation
- multifacteur
- récupération, départs

Keystone
les comptes locaux restants

- [security_compliance]
- TOTP du compte de secours
- exemptions par compte
- algorithme d'empreinte
- journaux d'audit

Gestion de secrets
les machines

- secrets générés, longs
- coffre, accès restreint
- rotation planifiée
- identifiants d'application
- alertes sur échecs

Règle d'architecture : la politique des personnes se règle à un seul endroit — l'autorité. Keystone n'applique sa propre politique qu'aux quelques comptes locaux qui lui restent.

Les secrets non humains — comptes de service, identifiants d'application — ne relèvent pas d'une politique de mot de passe mais d'une gestion de secrets : génération, stockage, rotation.

05

Appliquer la politique dans Keystone

Keystone dispose d'options de conformité pour ses comptes locaux : verrouillage, expiration, historique, complexité, inactivité, multifacteur. Elles sont désactivées par défaut, globales, et Sunbeam ne les expose pas : il faut savoir ce qu'elles font avant de décider où appliquer la politique.

- Les options de conformité
- Ce qu'elles ne couvrent pas
- Le multifacteur des comptes locaux
- Une configuration alignée sur le guide
- La stratégie sur Sunbeam

5 · APPLIQUER DANS KEYSTONE

Les options de conformité — `[security_compliance]`

Option	Effet	Guide	Exemption par compte
`lockout_failure_attempts`	verrouille après N échecs consécutifs	R10	`ignore_lockout_failure_attempts`
`lockout_duration`	durée du verrouillage en secondes ; sans valeur, verrouillage jusqu'à réactivation	R10	—
`password_expires_days`	expiration des mots de passe changés après activation	R24, R25	`ignore_password_expiry`
`unique_last_password_count`	nombre de derniers mots de passe interdits, l'actuel compris	R27	—
`minimum_password_age`	délai minimal entre deux changements, en jours	R27	—
`password_regex` , `password_regex_description`	règle de composition, et son explication affichée	R21, R23	—
`change_password_upon_first_use`	changement imposé après création ou réinitialisation par l'administration	R30	`ignore_change_password_upon_first_use`
`disable_user_account_days_inactive`	désactive les comptes sans authentification depuis N jours	R18	`ignore_user_inactivity`
— (options de compte)	`multi_factor_auth_enabled` , `multi_factor_auth_rules` , `lock_password`	R1	—

Toutes désactivées par défaut, et ne s'appliquent qu'au stockage SQL de Keystone : ni aux domaines LDAP, ni aux utilisateurs fédérés.

Globales : une seule valeur pour tout le cloud. La différenciation par population passe par les options d'exemption, posées compte par compte.

5 · APPLIQUER DANS KEYSTONE

Une configuration alignée sur le guide

```
# keystone.conf — comptes locaux restants :
# administration de secours et comptes techniques
[security_compliance]
# R10 : temporisation, pas de blocage définitif
lockout_failure_attempts = 5
lockout_duration = 900
# R25 : comptes locaux = comptes à privilèges
password_expires_days = 365
# R27 : historique
unique_last_password_count = 5
minimum_password_age = 1
# R21 / R22 : longueur d'abord, pas de maximum utile
password_regex = ^.{15,256}$
password_regex_description = Au moins 15 caractères.
# R30 : mot de passe remis par l'administration
change_password_upon_first_use = true
# R18 : comptes oubliés
disable_user_account_days_inactive = 90

[identity]
# R29- : PBKDF2 ; R29 : scrypt
password_hash_algorithm = scrypt
```

- **Expiration à 365 jours pour tous les comptes locaux :** cohérent avec R25 dès lors que les personnes ordinaires sont fédérées ; il ne reste en local que des comptes à privilèges.
- **Expression régulière centrée sur la longueur :** 15 caractères minimum, sans classes imposées ; la borne de 256 protège seulement contre les abus.
- `minimum_password_age` **inférieur à** `password_expires_days`**,** sinon impossible de changer avant expiration.
- **Expiration des mots de passe existants :** l'option ne s'applique qu'aux mots de passe changés après son activation.

Avant toute activation : poser les exemptions sur les comptes de service et le compte de secours — partie 6. Activer d'abord, exempter ensuite, c'est risquer de verrouiller le cloud.

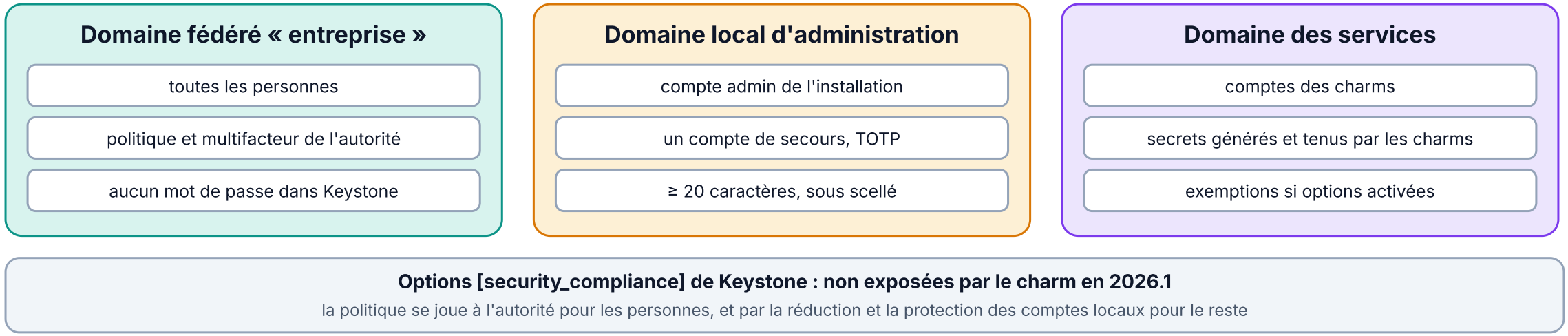
Valeurs proposées pour ce module, à valider par votre analyse de risque.

Ce que les options de Keystone ne couvrent pas

Exigence du guide	Keystone	Où la satisfaire
Liste de mots de passe compromis (R27)	**non**	autorité d'authentification
Refus des informations personnelles (R27)	**non, sauf par expression régulière**	autorité
Temporisation exponentielle (R10)	**durée fixe seulement**	autorité ; répartiteur de charge en frontal
Politique différente par population	**globale, avec exemptions**	autorité : une politique par groupe
Multifacteur par clé physique	**règles de méthodes, TOTP intégré**	autorité
Comptes d'un annuaire LDAP	**options sans effet**	l'annuaire lui-même
Utilisateurs fédérés	**options sans effet**	l'autorité
Alerte sur échecs répétés	**journaux et notifications d'audit**	centralisation des journaux, règles d'alerte

Conclusion : Keystone sait appliquer une politique raisonnable à quelques comptes locaux ; il n'est pas fait pour être l'autorité d'authentification d'une entreprise. C'est l'argument technique en faveur de la fédération.

La stratégie sur Sunbeam



- **Le charm de Keystone n'expose aucune option de conformité** en 2026.1 : ses options portent sur le cache, la journalisation, la région, le stockage d'identité et la paire de clés SAML.
- **Modifier `keystone.conf` dans le pod** n'est pas durable : le charm réécrit sa configuration.
- **Donc :** la politique des personnes va à l'autorité ; Keystone garde un minimum de comptes locaux, protégés par la longueur, le multifacteur et les procédures.
- **À suivre :** si une version ultérieure du charm expose ces options, appliquer la configuration de la slide précédente, exemptions d'abord.

5 · APPLIQUER DANS KEYSTONE

Le multifacteur des comptes locaux

```
# Prérequis : identifiants d'administrateur ; méthode
# totp acceptée par Keystone (à vérifier : [auth] methods)
source admin-openrc
SID=$(openstack user show secours \
  --domain "$OS_USER_DOMAIN_NAME" -f value -c id)

# 1 · Secret TOTP : 20 octets aléatoires, en base32
SECRET=$(head -c 20 /dev/urandom | base32 | tr -d '=')

# 2 · L'enregistrer comme justificatif du compte
openstack credential create --type totp "$SID" "$SECRET"

# 3 · Imposer mot de passe + totp
openstack user set "$SID" \
  --enable-multi-factor-auth \
  --multi-factor-auth-rule password,totp

# 4 · QR code pour l'application d'authentification
qrencode -t ansiutf8 \
  "otpauth://totp/OpenStack:secours?secret=$SECRET&issuer=OpenStack"

# 5 · Se connecter avec les deux méthodes
export OS_AUTH_TYPE=v3multifactor
export OS_AUTH_METHODS=v3password,v3totp
read -rs OS_PASSCODE; export OS_PASSCODE
openstack token issue
```

- **Règles de méthodes :** une liste de combinaisons acceptées ; `password,totp` exige les deux. Plusieurs règles peuvent coexister.
- **Le secret TOTP est stocké dans Keystone :** il fait partie de ce que R13 demande de protéger, comme les empreintes de mots de passe.
- **Horizon** doit savoir demander le code : à vérifier sur votre version avant de compter dessus pour le compte de secours.
- **Ne jamais activer le multifacteur sur un compte de service :** les services s'authentifient par mot de passe seul.

Compte local	Multifacteur
Administration de secours	**oui**
Administration nominative locale	**oui — ou fédérer la personne**
Comptes des services	**non**
Comptes techniques d'automates	**non : identifiants d'application**

> Le secret et le mot de passe du compte de secours sont conservés séparément, par deux personnes différentes.

06

L'impact sur les comptes de service

Une politique de mots de passe pensée pour des personnes, appliquée sans précaution à des comptes de machines, produit des pannes : verrouillage à distance, expiration un dimanche, changement imposé qu'aucun programme ne sait faire.

- Quatre risques
- Une stratégie par type de compte
- Exercices
- Les exemptions
- Activer sans casser
- Synthèse

Quatre risques

Verrouillage

`lockout_failure_attempts`

quelqu'un tape « nova » et
de faux mots de passe
→ Nova ne s'authentifie plus
→ le cloud ne crée plus rien

exemption
`ignore_lockout_failure_attempts`

Expiration

`password_expires_days`

le mot de passe du compte
expire à date fixe
→ tous les services liés
tombent le même jour

exemption
`ignore_password_expiry`

Premier usage

`change_password_upon_first_use`

après création ou
réinitialisation par script
→ changement exigé
qu'aucun service ne sait faire

exemption
`ignore_change_password_upon_first_use`

Inactivité

`disable_user_account_days_inactive`

un compte rarement utilisé —
le compte de secours —
→ désactivé sans bruit
→ indisponible le jour J

exemption
`ignore_user_inactivity`

Le plus grave est le verrouillage : il transforme une simple connaissance du nom d'un compte — `nova`, `neutron` — en moyen de mettre le cloud hors service, sans aucun mot de passe.

Ces risques concernent aussi les comptes techniques des automates qui s'authentifient par mot de passe. Les identifiants d'application, eux, ne passent pas par le mot de passe du compte.

Les exemptions

```
# Prérequis : identifiants d'administrateur
source admin-openrc

# Le domaine des services : son nom se lit, il ne se suppose pas
SVC=$(openstack domain list -f value -c Name | grep -i service)
openstack user list --domain "$SVC"

# Exempter chaque compte de service
for u in $(openstack user list --domain "$SVC" \
            -f value -c ID); do
  openstack user set "$u" \
    --ignore-lockout-failure-attempts \
    --ignore-password-expiry \
    --ignore-change-password-upon-first-use
done

# Inactivité, pour le compte de secours : par l'API
# (option sans équivalent dans le client selon les versions)
SID=$(openstack user show secours \
  --domain "$OS_USER_DOMAIN_NAME" -f value -c id)
TOKEN=$(openstack token issue -f value -c id)
curl -s -X PATCH "$OS_AUTH_URL/users/$SID" \
  -H "X-Auth-Token: $TOKEN" -H "Content-Type: application/json" \
  -d '{"user":{"options":{"ignore_user_inactivity":true}}}'

# Contrôle
openstack user show nova --domain "$SVC" -c options
```

Option de compte	À poser sur
`ignore_lockout_failure_attempts`	**comptes de service ; comptes techniques**
`ignore_password_expiry`	**comptes de service ; comptes techniques**
`ignore_change_password_upon_first_use`	**comptes de service ; comptes créés par script**
`ignore_user_inactivity`	**compte de secours ; comptes techniques peu utilisés**
`lock_password`	**comptes dont le secret est géré ailleurs**

- **Une exemption n'est pas une absence de contrôle :** elle déplace la protection vers la longueur du secret, son stockage et la surveillance des échecs.
- **Les exemptions sont visibles :** `openstack user show … -c options` ; les lister à chaque revue.

> Noms des options du client et de l'API à vérifier sur votre version. Sur Sunbeam, poser ces options sur les comptes gérés par les charms est sans risque pour eux, mais à refaire si un charm recrée son compte.

6 · COMPTES DE SERVICE

Une stratégie par type de compte

Type de compte	Secret	Protection à la place des règles humaines	Rotation	Surveillance
Comptes des services OpenStack	**généré par le charm, long, aléatoire**	accès restreint au nœud de contrôle, à Juju, à Vault	procédure du déploiement ; jamais à la main	échecs d'authentification sur ces comptes = alerte immédiate
Compte technique d'automate	**mot de passe ≥ 20 caractères, au coffre**	sert seulement à créer des identifiants d'application	trimestrielle, avec celle de ses identifiants	connexions par mot de passe hors fenêtre de rotation
Identifiant d'application	**secret généré par Keystone**	projet unique, rôle minimal, règles d'accès, expiration	avant l'expiration, sans coupure	usage depuis une adresse inattendue
Compte de secours	**≥ 20 caractères + TOTP, sous scellé**	multifacteur, deux détenteurs	après chaque usage, et au moins annuelle	toute connexion = alerte
Compte `admin` de l'installation	**généré par Sunbeam**	fichier `admin-openrc` confiné	selon la procédure du déploiement	toute connexion hors exploitation

Point commun : aucun de ces secrets n'est choisi ni tapé par une personne. Les règles de complexité n'ont pas de sens ; seules comptent la longueur, la confidentialité du stockage et la rotation.

Rapport au guide : le guide vise l'authentification des personnes et renvoie, pour les secrets entre machines, au RGS ; les règles de cette slide en sont une application raisonnée.

Activer sans casser : l'ordre des opérations

#	Étape
1	Inventorier les comptes locaux : `openstack user list --domain …` pour chaque domaine local
2	Classer chaque compte : personne, privilégié, secours, service, automate
3	Fédérer les personnes ; supprimer leurs comptes locaux
4	Remplacer les mots de passe d'automates par des identifiants d'application
5	Poser les exemptions sur les comptes de service et techniques
6	Vérifier les exemptions, compte par compte
7	Activer les options, une à une, sur un environnement d'essai
8	Essais : verrouillage d'un compte d'essai, pas d'un compte de service
9	Activer en production, hors période critique
10	Surveiller les échecs d'authentification pendant une semaine

```
# Étape 8 — essai de verrouillage, compte d'essai
openstack user create essai-verrou --domain nord \
  --password 'un-mot-de-passe-de-test-long-1'
for i in 1 2 3 4 5 6; do
  openstack --os-username essai-verrou \
    --os-user-domain-name nord --os-password faux \
    token issue 2>&1 | tail -1
done
# attendu : refus, puis compte verrouillé ;
# bon mot de passe refusé pendant lockout_duration

# Le même essai sur « nova » doit NE PAS verrouiller —
# à ne faire que sur un environnement d'essai
```

Ne jamais tester le verrouillage sur un compte de service en production : si l'exemption manque, le service tombe.

Retour arrière : désactiver l'option, puis réactiver les comptes verrouillés (`openstack user set --enable`).

Exercices de mise en pratique

#	Énoncé
1	**Écrire une règle de correspondance qui place les membres de `openstack-dev` dans `developpeurs` et refuse les comptes suspendus ; la tester hors ligne avec trois profils.**
2	**Raccorder un fournisseur d'identité au cloud Sunbeam du TP ; se connecter dans Horizon ; vérifier les droits effectifs de l'utilisateur fédéré.**
3	**Retirer l'utilisateur de son groupe chez l'autorité ; constater l'effet à la connexion suivante et sur un jeton déjà émis.**
4	**Remplir le tableau « politique par population » pour votre organisation ; justifier chaque valeur par une recommandation du guide.**
5	**Lister les comptes locaux du cloud et proposer, pour chacun, son devenir : fédéré, exempté, remplacé, supprimé.**
6	**Activer le multifacteur TOTP sur un compte de secours et se connecter en ligne de commande.**

Corrigé — points clés

- **1 :** condition `not_any_of` dans la règle d'accès elle-même ; une règle d'exclusion séparée ne retire rien.
- **2 :** même nom de fournisseur dans Sunbeam et dans Keystone ; identifiant distant exact.
- **3 :** plus de projet à la connexion suivante ; le jeton déjà émis reste valable jusqu'à son expiration.
- **4 :** pas d'expiration pour les comptes ordinaires robustes (R24) ; 1 à 3 ans et multifacteur pour les privilégiés (R25, R1).
- **5 :** attendu — personnes fédérées ; comptes des services exemptés ; automates sur identifiants d'application ; un compte de secours.
- **6 :** règle `password,totp` ; authentification `v3multifactor` avec les deux méthodes.

> Prérequis du TP : cloud Sunbeam avec TLS, `admin-openrc`, une autorité de test — Keycloak ou Canonical Identity Platform — joignable depuis le cloud et le poste.

SYNTHÈSE

Ce qu'il faut retenir

La fédération

- L'autorité authentifie ; Keystone traduit des attributs en groupes.
- Trois objets : fournisseur, règles, protocole.
- Règles testées hors ligne, versionnées, fermées par défaut.
- Sur Sunbeam : `sunbeam identity provider add`, puis les objets Keystone.

Le référentiel ANSSI

- Longueur d'abord : 12, 15, au moins 20 selon l'enjeu.
- Pas d'expiration systématique ; 1 à 3 ans pour les privilégiés.
- Temporisation plutôt que blocage définitif.
- Multifacteur pour tout accès sensible.

Les comptes de service

- Verrouillage, expiration, premier usage, inactivité : quatre pannes possibles.
- Exemptions posées avant d'activer.
- Secrets longs, aléatoires, stockés et tournés.
- Échec d'authentification = alerte.

Question	Réponse courte
Où appliquer la politique des personnes ?	**chez l'autorité d'authentification, raccordée par fédération**
Et dans Keystone ?	pour les seuls comptes locaux restants, avec exemptions pour les services
Sur Sunbeam ?	options de conformité non exposées par le charm : fédérer les personnes, réduire les comptes locaux, multifacteur sur le compte de secours
Le piège principal ?	un verrouillage activé sans exemption sur les comptes des services

Sources : ANSSI, Recommandations relatives à l'authentification multifacteur et aux mots de passe, v2.0 (2021) ; documentation de Keystone (configuration, options de compte, fédération, règles de correspondance) ; documentation de Canonical OpenStack 2026.1 (fournisseurs d'identité, TLS par Vault) ; page de configuration du charm keystone-k8s — consultées en octobre 2026.